

18. Webové aplikace - autentizace a autorizace

Autentizace

- Kdo jsi?
- Proces ověření uživatele
- Jméno a heslo, faceID, otisk prstu, PIN,...
- Nikdy se neukládají v čisté podobě
- Používají se hashovací algoritmy (např. BCrypt + salt)
- Dnes pro větší bezpečnost dvoufázové ověření – po zadání hesla nebo jiných ověřovacích údajů je potřeba ještě jeden způsob k dodání toho že je to opravdu ten člověk (např. jednorázový kód v emailu, klíč z 2FA aplikace)
- Možnost delegace na:
 - OAuth 2.0: Standard pro delegování přístupu například přes Google, Facebook, a další, webu se poté nedávají přístupové údaje ale jen email
 - OpenID Connect: Nadstavba nad OAuth, která řeší právě tu identitu

Uchování přihlášení na webu

- Session – stav se ukládá na serveru, vytvoří se unikátní ID a to se uloží do Cookie v prohlížeči, podle něj poté ověřuje uživatele a jeho stav
- Tokeny - JWT - JSON Web Token, stav se ukládá u uživatele, token je zašifrovaný a podepsaný serverem, výhoda je škálovatelnost a "stateless" přístup

Autorizace

- Co můžeš dělat?
- Proces ověření práv přihlášeného uživatele
- Typy řízení přístupu:
 - Role-Based Access Control – přístup do částí webu na základě rolí, pokud do dané sekce uživatel nemá přístup app hodí 403 Forbidden
 - Access Control List - konkrétní seznam práv pro konkrétní uživatele k danému objektu (např. v Google Drive – konkrétní e-maily mají právo "číst")